

Chiến Lược Bảo Mật API Toàn Diện Trong Kỷ Nguyên AI

Bảo mật không phải là chi phí, mà là giá trị cạnh tranh

Comprehensive API Security Strategy in AI Era

Security is not a cost, but a competitive advantage

Nội dung chính

- 1 Tư duy mới - Bảo mật là bài toán kinh doanh
- 2 Chiến lược công nghệ - SSDLC & Infrastructure as Code
- 3 Thực thi hiện đại - Spec-Driven, BDD & AI Guardrails
- 4 Chi tiết OWASP API Top 10 & Cách giảm thiểu
- 5 Tổng kết & Lộ trình cho Team

Agenda

- 1 New Mindset - Security as Business Concern
- 2 Technology Strategy - SSDLC & Infrastructure as Code
- 3 Modern Implementation - Spec-Driven, BDD & AI Guardrails
- 4 Detailed OWASP API Top 10 & Mitigation
- 5 Summary & Action Plan for Team

TƯ DUY MỚI – BẢO MẬT LÀ BÀI TOÁN KINH DOANH

 **Phá vỡ định kiến: Bảo mật không chỉ là "chi phí IT"**

-  **Bảo mật là Giá trị cạnh tranh** - Rò rỉ dữ liệu gây thiệt hại danh tiếng nặng nề hơn chi phí đầu tư
-  **Lượng hóa rủi ro** - Xác định rủi ro không thể chấp nhận, tính toán chi phí vi phạm vs. chi phí đầu tư
-  **Quy tắc 80/20** - 80% rủi ro giảm thiểu bằng yếu tố con người và quy trình đúng đắn

 **Chấp nhận rủi ro thông minh**

-  **Bảo mật không bao giờ là 100%** - Tồn kém vô ích, cần xác định mức độ chấp nhận
-  **Xác định "Mức độ rủi ro chấp nhận được"** - Cùng khách hàng quyết định
-  **Biến yêu cầu bảo mật thành kịch bản nghiệp vụ** - Quyết định đầu tư dựa trên giá trị kinh doanh



NEW MINDSET – SECURITY AS BUSINESS CONCERN

🛡️ **Breaking Stereotypes: Security is not just "IT cost"**

↗️ **Security as Competitive Advantage** - Data breach damages reputation far more than tool investment

📊 **Risk Quantification** - Identify unacceptable risks, calculate breach costs vs. investment costs

🕒 **80/20 Rule** - 80% of risks mitigated through proper human factors and processes

🛡️ **Smart Risk Acceptance**

🔍 **Security is never 100%** - Impractical expense, need to determine acceptable level

🤝 **Determine "Acceptable Risk Level"** - Decide together with clients

📋 **Transform security requirements into business scenarios** - Investment decisions based on business value



CHIẾN LƯỢC CÔNG NGHỆ – SSDLC & INFRASTRUCTURE AS CODE

🛡️ **Shift-Left Security: Bảo mật từ gốc rễ**

🕒 **Quản lý Dependencies** - Cập nhật định kỳ để tránh rủi ro (Bài học Log4j)

🕒 **Stale Dependencies** - Nhận diện thư viện "chết" (>6-12 tháng) để thay thế

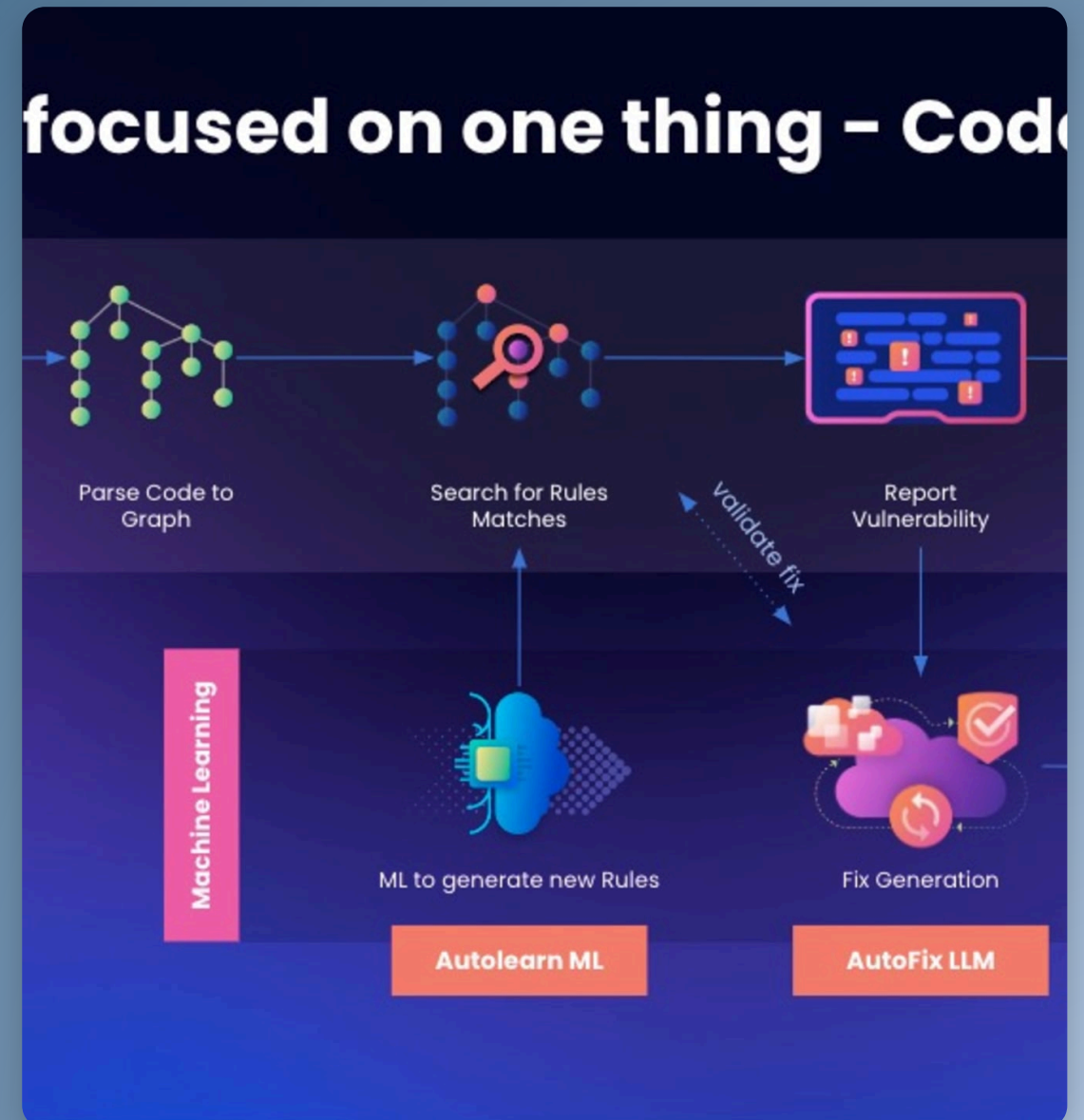
🔧 **"Fix the roof while the sun is shining"** - Tự động quét lỗi hổng hàng ngày

⚙️ **Hardening & Platform Services**

<> **Vô hiệu hóa yếu tố con người** - Triển khai GitOps qua Pull Request và Review

🏠 **Cơ cấu Platform** - WAF, API Gateway, Identity Provider thành dịch vụ nền tảng

🔒 **Least Privilege** - Phân đoạn mạng để giảm thiểu "Blast Radius"



TECHNOLOGY STRATEGY – SSDLC & INFRASTRUCTURE AS CODE

- 🛡️ **Shift-Left Security: Security from the roots**
- 🕒 **Dependency Management** - Regular updates to avoid risks (Log4j lesson)
- 🗑️ **Stale Dependencies** - Identify "dead" libraries (>6-12 months) for replacement
- 🔧 **"Fix the roof while the sun is shining"** - Automated daily vulnerability scanning

- ⚙️ **Hardening & Platform Services**
- 🔗 **Eliminate human factors** - Deploy GitOps through Pull Request and Review
- 🏢 **Platform Architecture** - WAF, API Gateway, Identity Provider as platform services
- 🔒 **Least Privilege** - Network segmentation to minimize "Blast Radius"



THỰC THI HIỆN ĐẠI – SPEC-DRIVEN, BDD & AI GUARDRAILS

 **Spec-Driven Development: Nguồn sự thật duy nhất**

 **OpenAPI Spec (OAS)** là điều kiện bắt buộc trước khi code

 **Nội dung Spec** - Data validation, Auth Scopes, Rate Limits trong YAML/JSON

 **BDD: Bảo mật dựa trên hành vi**

 **Ngôn ngữ bình dân** - Biến 10 rủi ro OWASP thành Gherkin

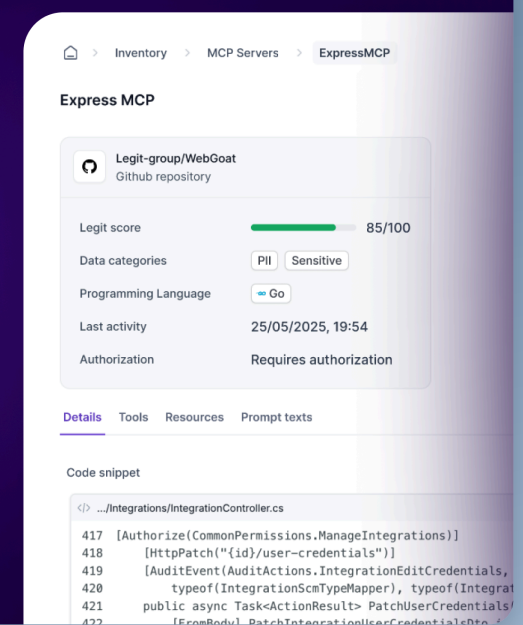
 **Ví dụ BOLA** - Given/When/Then để test truy cập trái phép

 **Vibe Coding với Project-Codeguard**

 **AI as an Ally** - Tăng tốc với Cursor/Copilot + Guardrails

 **Project-Codeguard** - .cursorrules, quét real-time

Discovery



Ví dụ BDD cho BOLA:

Scenario: Truy cập trái phép đơn hàng

Given: Tôi là User A

When: Tôi GET `/api/orders/B`

Then: Hệ thống trả về 403 (Forbidden)

MODERN IMPLEMENTATION – SPEC-DRIVEN, BDD & AI GUARDRAILS

📄 Spec-Driven Development: Single Source of Truth

- 📋 **OpenAPI Spec (OAS)** is mandatory contract before coding
- ✂️ **Spec Content** - Data validation, Auth Scopes, Rate Limits in YAML/JSON

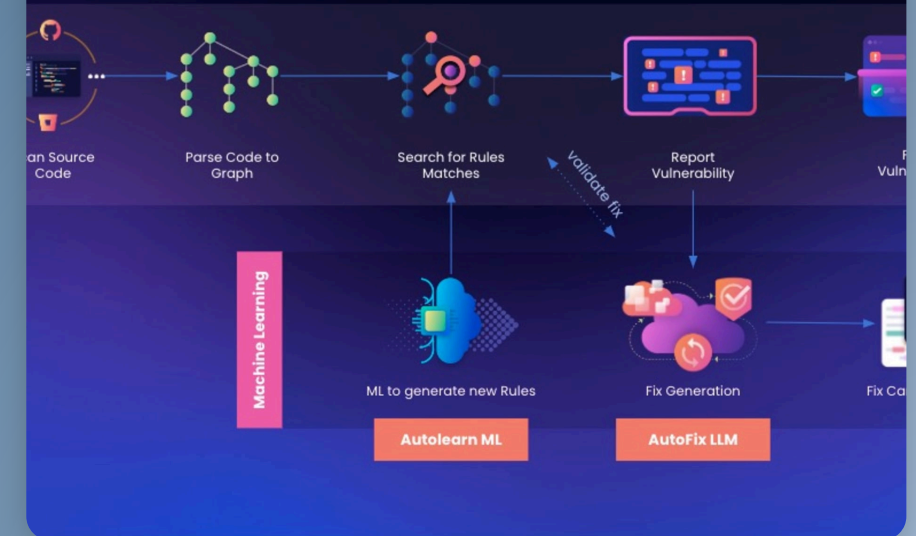
🧠 BDD: Behavior-Driven Security

- 🗨️ **Plain Language** - Transform 10 OWASP risks into Gherkin
- 🛠️ **BOLA Example** - Given/When/Then to test unauthorized access

🛠️ Vibe Coding with Project-Codeguard

- 🛡️ **AI as an Ally** - Accelerate with Cursor/Copilot + Guardrails
- 🛡️ **Project-Codeguard** - .cursorrules, real-time scanning

Hybrid AI focused on one thing – Code Security



BDD Example for BOLA:

Scenario: Unauthorized order access
 Given: I am User A
 When: I GET "/api/orders/B"
 Then: System returns 403 (Forbidden)

CHI TIẾT OWASP API TOP 10 & CÁCH GIẢM THIỂU

Lỗi hỏng (Risk)	Giải pháp từ Spec & BDD	Vai trò của AI & Codeguard
 API1: BOLA	Dùng Information Model để định nghĩa quyền sở hữu Object	AI tự chèn filter owner_id vào query
 API2: Broken Auth	Áp dụng chính sách Token đồng nhất trên toàn Platform	Codeguard chặn code thiếu Middleware Auth
 API3: BPLA	Spec hóa các trường dữ liệu nhạy cảm (ReadOnly/Internal)	AI tự động lọc (Masking) dữ liệu nhạy cảm ở Response
 API4: Resource Consumption	Khai báo Rate Limit theo gói hợp đồng của khách hàng	AI gợi ý tích hợp Redis/Throttling logic
 API5: BFLA	Ma trận phân quyền Role-based (RBAC) trong Spec	Quét Annotation @Roles trên Controller
 API6: Business Flow	Định nghĩa State Machine cho các luồng nhạy cảm	Đảm bảo logic "Không thanh toán nếu chưa đặt hàng"
 API7: SSRF	Chặt chẽ hóa Input validation trong Spec	AI cảnh báo khi thấy hàm thực thi URL từ User

DETAILED OWASP API TOP 10 & MITIGATION

Risk	Solution from Spec & BDD	Role of AI & Codeguard
 API1: BOLA	Use Information Model to define Object ownership	AI automatically inserts owner_id filter into query
 API2: Broken Auth	Apply unified Token policy across Platform	Codeguard blocks code missing Auth Middleware
 API3: BPLA	Spec sensitive data fields (ReadOnly/Internal)	AI automatically masks sensitive data in Response
 API4: Resource Consumption	Declare Rate Limit according to client contract	AI suggests Redis/Throttling logic integration
 API5: BFLA	Role-based (RBAC) permission matrix in Spec	Scan @Roles Annotation on Controller
 API6: Business Flow	Define State Machine for sensitive flows	Ensure logic "No payment without order"
 API7: SSRF	Tighten Input validation in Spec	AI warns when URL execution function from User

TỔNG KẾT & LỘ TRÌNH CHO TEAM (ACTION PLAN)



BA/PO

Khi viết Requirement, phải đính kèm kịch bản BDD Security (Happy & Unhappy paths)



Architect

Thiết kế OpenAPI Spec hoàn chỉnh trước khi cho phép Dev bắt đầu "Vibe coding"



Developer

Sử dụng AI kết hợp với Guardrails của dự án. Nguyên tắc: **"No Spec, No Code"**



QA

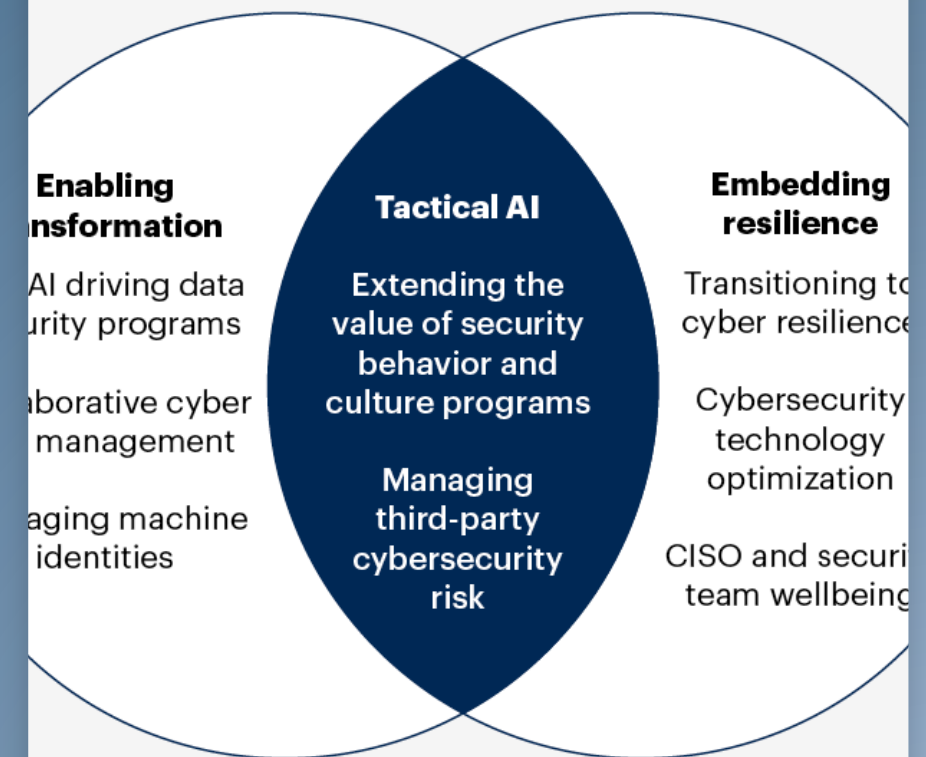
Tự động hóa 100% các kịch bản bảo mật trong CI/CD. Kiểm tra tính **Consistent** (Nhất quán) của test



PM

Đưa bảo mật vào ngân sách Business của dự án. Báo cáo rủi ro dựa trên giá trị kinh tế thay vì lỗi kỹ thuật

Cybersecurity for 2025



ts reserved. 3363616

Lời kết

Trong Outsourcing, tốc độ của AI cộng với kỷ luật của Spec-driven chính là chìa khóa để chiếm trọn lòng tin của khách hàng.

SUMMARY & ACTION PLAN FOR TEAM



BA/PO

When writing Requirements, must attach BDD Security scenarios (Happy & Unhappy paths)



Architect

Design complete OpenAPI Spec before allowing Dev to start "Vibe coding"



Developer

Use AI combined with project Guardrails. Principle: **"No Spec, No Code"**



QA

Automate 100% security scenarios in CI/CD. Verify test **Consistency**



PM

Include security in project Business budget. Report risks based on economic value rather than technical errors

ns Categories

Key Capabilities:

- **Automated Network Inventory:** Continuously scans and updates asset registries.
- **Real-Time Vulnerability Assessment:** Integrates vulnerability intelligence (CVE, CVSS) with contextual risk metrics.
- **SBOM/KBOM Integration:** Tracks software and hardware components for quick identification of security gaps.
- **Risk-Based Prioritization:** Uses data-driven models to address high-impact vulnerabilities first.

Key Capabilities:

- **Process Anomaly Detection:** Identifies deviations in machine behavior or production parameters.
- **Sensor Signal Integrity:** Monitors and validates data sources to prevent manipulation or spoofing.
- **Predictive Maintenance Integration:** Uses operational data to anticipate failures, minimizing unplanned downtime.
- **AI-Driven Analysis:** Leverages machine learning for faster detection of subtle shifts in operational health.



Identity and Access Management (IAM)

IAM ensures that only authorized users and devices can interact with industrial systems. By employing centralized identity governance and zero-trust principles, organizations enforce strict controls over who accesses critical processes. Modern IAM extends beyond user authentication to include device identity, privileged access management, and robust audit trails for regulatory compliance.



Industrial IoT (IIoT) Device Security

As IIoT devices proliferate, securing them is paramount. Modern solutions emphasize continuous vulnerability assessment, embedded inventory agents, and secure over-the-air (OTA) updates. These measures ensure that as organizations scale their IIoT footprint, they do so with robust protections against unauthorized access, data breaches, and operational disruptions.



Key Takeaway

In Outsourcing, the speed of AI combined with Spec-driven discipline is the key to winning client trust.

CẢM ƠN VÀ HỎI ĐÁP

Trong sản xuất phần mềm, tốc độ của AI cộng với kỷ luật của Spec-driven chính là chìa khóa để chiếm trọn lòng tin của khách hàng

Liên hệ NTQ Security Team

✉ security@ntq.com.vn

👤 hung.nguyen17 @ NTQ Security Team

THANK YOU & Q&A

In software development, the speed of AI combined with
Spec-driven discipline is key to winning client trust

Contact NTQ Security Team

✉ security@ntq.com.vn

👤 hung.nguyen17 @ NTQ Security Team